SafePay's silent sweep Over 600 organizations have been crippled since 2024. Are we still treating stolen VPN creds like a low-risk alert?

$ **SAFEPAY'S SILENT SWEEP**

⚠ THREAT BRIEF SafePay ransomware is no longer a novelty; it’s a full-blown supply-chain nightmare. It leverages stolen credentials, **VPN** access, and **double extortion** to force payment. The joint advisory from **FBI**, **CISA**, the U.S. Secret Service, and European law-enforcement agencies underscores the scale. 600+ victims, relentless credential-theft campaigns, and a shift toward targeting critical infrastructure.

$ **SAFEPAY'S SILENT SWEEP**

▯ OPERATIONAL REALITY What most teams assume: **MFA** and periodic password rotation will stop **SafePay**. What actually happens: attackers harvest valid MFA tokens, hijack existing **VPN** tunnels. They blend into normal traffic, rendering our usual alerts meaningless. Last week our SOC flagged a rogue **VPN** login from a known IP. Within minutes the attacker pivoted to ransomware staging, and our SIEM was flooded with false positives that drowned the real IOC.

[redacted] OPERATIONAL CHECKLIST • Enforce **Zero-Trust** network segmentation for all remote access points. • Deploy continuous credential-anomaly detection on **VPN** gateways. • Correlate **IOC** feeds with internal auth logs in real time via **SOAR**. • Harden endpoint protection on all privileged workstations; default to **application whitelisting**. • Conduct weekly red-team simulations that include stolen token reuse scenarios. Stop the bleed.

🔒 HARD LESSONS Our incident response playbook still treats credential theft as a “low-severity” ticket. The reality is that **SafePay** uses those creds to establish a foothold, then leverages **double extortion** to pressure the boardroom. The cost of a single breach now includes ransom, legal fees, and brand erosion—often exceeding $5 M per incident.

▯ Tool Recommendation **Bitdefender Antivirus** (▯ 0) – A lightweight, signature-based engine that still catches the legacy payloads **SafePay** drops after encryption. Its real-time kernel protection and network intrusion module give us a final line of defense when the VPN tunnel is already compromised. Deploy it everywhere on privileged assets.

[NO GLYPH] POWER CLOSING **In 12 months, any SOC that relies on manual VPN credential reviews will be a sitting duck—automation isn’t optional, it’s survival.**

NOGLYPH Source: https://securityaffairs.com/201464/cyber-crime/fbi-ar
#SupplyChainSecurity #Ransomware #SOC
#ZeroTrust #VPN